

Relazione Tecnica di Vulnerability Assessment

Scansione di Rete e Analisi delle Vulnerabilità su Ambiente Metasploitable

Target: 192.168.50.2 | Strumento: Nmap 7.99

Data esecuzione scansione: 9 luglio 2026

Documento redatto per finalità didattiche e di analisi strategica.

1. Sintesi

La presente relazione documenta l'attività di network scanning condotta sulla macchina target Metasploitable (indirizzo IP 192.168.50.2), un ambiente intenzionalmente vulnerabile utilizzato a scopo didattico per l'addestramento in ambito cyber security. L'attività, eseguita mediante lo strumento Nmap, ha permesso di identificare 22 porte TCP aperte e i relativi servizi in esecuzione. L'analisi ha evidenziato la presenza di numerose vulnerabilità critiche, tra cui backdoor note nei servizi FTP (vsftpd, ProFTPD), IRC (UnrealIRCd) e una shell di root esposta senza autenticazione sulla porta 1524. Il documento illustra la metodologia adottata, i risultati della scansione, la valutazione dei rischi associati a ciascun servizio e le raccomandazioni di mitigazione secondo le best practice di settore.

2. Obiettivo e Metodologia

Obiettivo dell'attività è stato eseguire una scansione di rete completa per identificare host attivi, porte aperte e servizi in esecuzione sul sistema target, propedeutica a una successiva valutazione delle vulnerabilità e dei rischi associati, in linea con le pratiche standard di Vulnerability Assessment & Penetration Testing (VAPT).

2.1 Strumento e Comando Utilizzato

La scansione è stata effettuata con Nmap versione 7.99, tramite il seguente comando:

```
nmap -sV -oG scan_results.grep 192.168.50.2
```

L'opzione -sV abilita il rilevamento della versione dei servizi (service/version detection), fondamentale per associare a ciascuna porta la relativa vulnerabilità nota (CVE).

2.2 Ambiente di Test

- Target: 192.168.50.2 (Metasploitable 2, macchina virtuale intenzionalmente vulnerabile)
- Rete: ambiente di laboratorio isolato (host-only / NAT)
- Durata scansione: 12,19 secondi
- Esito: host attivo (Up), 22 porte aperte su 977 analizzate come chiuse

3. Risultati della Scansione Nmap

La scansione ha rilevato l'host attivo e un totale di 22 porte TCP aperte, con relativa identificazione del servizio e, ove possibile, della versione software. La tabella seguente riassume i risultati grezzi ottenuti.

Porta	Protocollo	Servizio / Versione	Vulnerabilità Nota	CVE / Rif.	Rischio
21	tcp	FTP – vsftpd 2.3.4	Backdoor: una stringa di login contenente ":" apre una shell remota sulla porta 6200/tcp.	CVE-2011-2523	Critico
22	tcp	SSH – OpenSSH 4.7p1 (Debian 8ubuntu1)	Versione obsoleta con debolezze note nella generazione delle chiavi (Debian OpenSSL PRNG) e vettori di user-enumeration.	CVE-2008-0166	Medio
23	tcp	Telnet – Linux telnetd	Protocollo in chiaro: credenziali e traffico intercettabili via	CWE-319	Alto

Porta	Protocollo	Servizio / Versione	Vulnerabilità Nota	CVE / Rif.	Rischio
			sniffing; nessuna cifratura.		
25	tcp	SMTP – Postfix smtpd	Possibile uso come open relay e information disclosure tramite comandi VRFY/EXPN per l'enumerazione utenti.	CWE-200	Medio
53	tcp	DNS – ISC BIND 9.4.2	Versione datata soggetta a cache poisoning e a diverse CVE di denial-of-service.	CVE-2008-0122	Medio
80	tcp	HTTP – Apache 2.2.8 (Ubuntu) DAV/2	Versione end-of-life; modulo WebDAV e applicazioni web di test (DVWA, Mutillidae) con SQLi/XSS/LFI note.	CVE-2009-1891	Alto
111	tcp	RPC – rpcbind	Espone il mapping dei servizi RPC, facilitando l'enumerazione di NFS/NIS e attacchi successivi.	CWE-200	Basso
139/445	tcp	SMB – Samba 3.X - 4.X	Vulnerabile all'exploit "username map script" che consente esecuzione di comandi remoti non autenticata.	CVE-2007-2447	Critico
512	tcp	Rexec – netkit-rsh rexecd	Autenticazione in chiaro basata su username/password trasmessi senza cifratura.	CWE-319	Alto
513	tcp	Rlogin	Autenticazione basata su relazioni di fiducia host (.rhosts) facilmente aggirabile.	CWE-287	Alto
514	tcp	Rsh – Netkit rshd	Esecuzione di comandi remoti con autenticazione debole basata su IP/hostname.	CWE-287	Alto
1099	tcp	Java RMI – GNU Classpath grmiregistry	Il registro RMI privo di restrizioni consente il caricamento di classi da remoto ed esecuzione di codice arbitrario.	CVE-2011-3556	Alto
1524	tcp	Bindshell – Metasploitable root shell	Shell di root residua lasciata aperta da un precedente exploit	N/D (backdoor)	Critico

Porta	Protocollo	Servizio / Versione	Vulnerabilità Nota	CVE / Rif.	Rischio
			(ingres/distccd): accesso diretto senza autenticazione.		
2049	tcp	NFS	Condivisioni NFS esportate con permessi eccessivi (no_root_squash), possibile lettura/scrittura non autorizzata.	CWE-732	Medio
2121	tcp	FTP – ProFTPD 1.3.1	Versione del pacchetto distribuita con un backdoor nel codice sorgente che consente RCE.	CVE-2010- 4221	Critico
3306	tcp	MySQL 5.0.51a-3ubuntu5	Account root privo di password e versione obsolescente con diverse vulnerabilità note.	CVE-2009- 2446	Alto
5432	tcp	PostgreSQL 8.3.0 - 8.3.7	Autenticazione debole/credenziali di default; versione soggetta a privilege escalation.	CVE-2013- 1899	Medio
5900	tcp	VNC (protocollo 3.3)	Protocollo legacy con autenticazione debole (password a 8 caratteri, DES) e traffico non cifrato.	CWE-326	Alto
6000	tcp	X11	Accesso negato in fase di scansione, ma il servizio X11 esposto rappresenta comunque una superficie di attacco potenziale.	CWE-200	Basso
6667	tcp	IRC – UnrealIRCd	Versione del binario compromessa con backdoor: una stringa specifica nel comando consente RCE.	CVE-2010- 2075	Critico
8009	tcp	AJP – Apache JServ Protocol v1.3	Protocollo AJP esposto, vettore per attacchi di tipo "Gh0stcat" (lettura file arbitraria / file inclusion).	CVE-2020- 1938	Alto
8180	tcp	HTTP – Apache Tomcat/Coyote 1.1	Manager Application con credenziali di default che consente il deploy di WAR malevoli e RCE.	CVE-2009- 3843	Alto

4. Analisi delle Vulnerabilità Identificate

Di seguito si riportano le vulnerabilità più rilevanti individuate, raggruppate per criticità, con relativa motivazione tecnica.

4.1 Vulnerabilità Critiche

- vsftpd 2.3.4 (porta 21): la versione del pacchetto in uso è stata compromessa nel codice sorgente e contiene una backdoor attivabile inserendo la sequenza ":" nel campo username, che apre una shell di comando sulla porta 6200/tcp (CVE-2011-2523).
- Samba 3.X (porte 139/445): affetto dalla vulnerabilità "username map script", che consente l'esecuzione di comandi arbitrari senza autenticazione (CVE-2007-2447).
- Bindshell su porta 1524: shell di root residua, raggiungibile senza alcuna autenticazione — rappresenta il rischio più immediato per la compromissione totale del sistema.
- ProFTPD 1.3.1 (porta 2121): pacchetto distribuito con backdoor che consente l'esecuzione di comandi remoti (CVE-2010-4221).
- UnrealIRCd (porta 6667): binario compromesso con backdoor attivabile da remoto (CVE-2010-2075).

4.2 Vulnerabilità di Rischio Alto

- Servizi "r" (rexec, rlogin, rsh — porte 512-514): basati su autenticazione debole (fiducia per IP/hostname) e trasmissione in chiaro delle credenziali.
- Java RMI Registry (porta 1099): privo di restrizioni sul caricamento di classi remote, sfruttabile per esecuzione di codice arbitrario (CVE-2011-3556).
- MySQL 5.0.51a (porta 3306): account amministrativo (root) privo di password.
- VNC protocollo 3.3 (porta 5900): meccanismo di autenticazione debole e traffico non cifrato.
- Apache Tomcat 8180: applicazione Manager con credenziali di default che consente il deploy di WAR malevoli (CVE-2009-3843).
- AJP Connector (porta 8009): esposto e vulnerabile alla tecnica "Ghostcat" per la lettura di file arbitrari (CVE-2020-1938).

4.3 Vulnerabilità di Rischio Medio e Basso

Servizi come Telnet, SMTP (Postfix), DNS (BIND 9.4.2), NFS e PostgreSQL presentano versioni obsolete e configurazioni permissive che, pur non offrendo un accesso diretto immediato, ampliano la superficie di attacco e possono essere sfruttati come vettori secondari in una catena di compromissione (lateral movement). I servizi rpcbind e X11 espongono informazioni utili in fase di ricognizione (information disclosure) ma con impatto diretto limitato.

5. Valutazione dei Rischi

Applicando una matrice di rischio basata su probabilità di sfruttamento e impatto potenziale, i 22 servizi identificati si distribuiscono come segue:

Livello di Rischio	N. Servizi Coinvolti	% sul Totale
Critico	5	23%
Alto	10	45%
Medio	5	23%
Basso	2	9%

Il dato più significativo è che oltre il 60% dei servizi esposti presenta un livello di rischio Alto o Critico, a conferma della natura volutamente vulnerabile dell'ambiente Metasploitable. In un contesto reale, una simile esposizione comporterebbe un rischio concreto di compromissione totale del sistema (full system compromise) in tempi molto

brevi, anche da parte di un attaccante con competenze limitate, data la disponibilità pubblica di exploit per la maggior parte delle vulnerabilità elencate.

6. Raccomandazioni di Mitigazione

6.1 Azioni Immediate

- Disattivare o rimuovere i servizi non necessari (rexec, rlogin, rsh, bindshell su 1524, X11 remoto).
- Aggiornare tutti i pacchetti a versioni supportate e patchate, in particolare vsftpd, ProFTPD, Samba, UnrealIRCd, BIND e Apache/Tomcat.
- Sostituire Telnet con SSH e disabilitare l'autenticazione con password in favore di chiavi crittografiche.
- Impostare password complesse per tutti gli account di database (MySQL, PostgreSQL) ed eliminare gli account privi di credenziali.

6.2 Misure Strutturali

- Applicare il principio del privilegio minimo e segmentare la rete per limitare la superficie esposta ai soli servizi strettamente necessari.
- Implementare un'architettura Zero Trust, autenticando e ispezionando ogni richiesta indipendentemente dalla provenienza.
- Adottare l'autenticazione multi-fattore (MFA) resistente al phishing per l'accesso ai servizi amministrativi.
- Pianificare scansioni di vulnerabilità periodiche (es. tramite Nessus) e definire un processo strutturato di patch management.

7. Conclusioni

La scansione condotta con Nmap ha fornito una mappatura completa dei servizi esposti dall'host target, evidenziando un numero elevato di vulnerabilità critiche coerenti con la natura didattica dell'ambiente Metasploitable. I risultati ottenuti costituiscono la base per la successiva fase di vulnerability assessment automatizzato tramite Nessus, che consentirà di confermare e approfondire ulteriormente le criticità identificate, corredandole di uno scoring di rischio standardizzato (CVSS).

La cyber security non è un prodotto, ma un processo continuo: la remediation delle vulnerabilità individuate deve essere accompagnata da un piano di monitoraggio costante e da una revisione periodica della postura di sicurezza dell'infrastruttura.